Implement and Manage Zero Trust Network Access (ZTNA) using Zscaler

TEAM DETAILS

S.NO	NAME	COLLEGE	CONTACT
1	SADANAPRIYA . K	St.joseph's college for women,Tiruppur	sadanapriyakannan@gmail.com
2	MAHALAKSHMI . M	St.joseph's college for women,Tiruppur	maha08lakshmi08m@gmail.com
3	PRIYADHARSHINI.M	St.joseph's college for women,Tiruppur	priyadharshinim821@gmail.com
4	SHALINI . M	St.joseph's college for women,Tiruppur	shalini97837@gmail.com

PROJECT DETAILS

Title: Implement and manage Zero Trust Network Access (ZTNA) using Zscaler

Zero Trust Network Access (ZTNA).

Zero Trust Network Access (ZTNA) is a modern security approach that ensures secure access to applications by verifying every user, device, and connection before granting permission. Traditional network security models assume that users inside the network can be trusted, but the Zero Trust model follows the principle of **"never trust, always verify."** In this project, the ZTNA architecture is implemented using **Zscaler**, a cloud-based security platform that enables secure user-to-application connectivity without exposing internal networks to the internet. The system allows users to securely access private applications from any location while ensuring strict identity verification and access control. Instead of providing full network access like traditional VPNs, ZTNA grants **application-level access** based on policies such as user identity, device posture, and location. Zscaler acts as a secure broker between users and applications, ensuring that applications remain hidden from unauthorized users and reducing the attack surface.

This project demonstrates how **Zscaler's Zero Trust architecture** protects enterprise resources by continuously authenticating users, inspecting traffic, and enforcing security policies. By implementing ZTNA, organizations can improve security, reduce the risk of cyberattacks, and provide seamless remote access to applications without compromising network safety. The solution is especially useful in modern cloud environments where users work remotely and access applications from different devices and locations.

Abstract:

With the rapid growth of cloud computing and remote work, traditional network security models such as VPNs are no longer sufficient to protect organizational resources. Zero Trust Network Access (ZTNA) is a modern security framework that follows the principle of **"never trust, always verify,"** ensuring that every user and device is authenticated and authorized before accessing applications. This project focuses on implementing ZTNA using **Zscaler**, a cloud-based security platform that provides secure and controlled user-to-application connectivity. The system ensures that users can securely access internal applications without exposing the entire network to potential threats. Instead of granting broad network access, ZTNA provides **application-level access** based on identity, device posture, and security policies. Zscaler acts as an intermediary that authenticates users, verifies device security, and enforces access policies while keeping applications hidden from the public internet.The proposed solution enhances security by reducing the attack surface, preventing unauthorized access, and protecting sensitive organizational data. It also improves user experience by enabling seamless and secure remote access to applications from any location. By adopting ZTNA with Zscaler, organizations can strengthen their cybersecurity posture, support modern work environments, and ensure safe connectivity between users and applications.

Use Case Scenarios:

Scenario 1: Remote Employee Access to Internal Application.

In modern organizations, many employees work remotely and need to access internal applications from outside the company network. Traditional VPN-based systems often provide full network access, which increases security risks. With Zero Trust Network Access (ZTNA), the system verifies the identity of the employee before allowing access. The user attempts to log in to the organization's internal application using their credentials. The ZTNA system checks user identity, device posture, and security policies before granting permission. Instead of giving access to the entire network, the system allows access only to the specific application requested. This approach ensures that sensitive company resources remain protected while still enabling employees to work efficiently from remote locations.

Output:

- The user identity is verified through secure authentication.
- The device security posture is checked before granting access.
- A secure connection is established between the user and the application.
- Access is granted only to the specific authorized applications.

Scenario 2: Unauthorized User Attempting Access.

Cyber attackers often try to gain unauthorized access to internal enterprise applications by using stolen credentials or attempting to bypass security systems. In this scenario, an unknown user tries to access a private company application without valid authentication. The Zero Trust model ensures that no user or device is trusted by default. When the access request is made, the ZTNA system immediately verifies the identity of the user and checks the access policy. Since the user does not meet the authentication requirements, the system blocks the connection attempt. The application itself remains invisible to unauthorized users, preventing attackers from even detecting its presence. All suspicious activities are recorded for monitoring and analysis.

Output:

- Invalid authentication is detected by the system.
- The access request is automatically denied.
- The application remains hidden from unauthorized users.
- The access attempt is logged for security monitoring.

Scenario 3: Device Security Compliance Check.

Organizations often enforce security policies to ensure that only secure and trusted devices can access company resources. In this scenario, a user attempts to access an internal application using a device that may not meet the organization's security requirements. The ZTNA system performs a device posture check, which includes verifying antivirus status, operating system updates, and device compliance. If the device fails to meet the required security standards, the system restricts or blocks access. This helps prevent potential threats from compromised or vulnerable devices. By ensuring that only secure devices can connect to applications, the organization can reduce the risk of malware attacks and data breaches.

Output:

- The device security status is analyzed by the system.
- Non-compliant devices are automatically detected.
- Access to the application is restricted or denied.
- The user receives instructions to update device security.

Scenario 4: Role-Based Access Control.

In an organization, different employees have different responsibilities and access requirements. For example, managers, developers, and interns may need access to different applications. In this scenario, the ZTNA system enforces role-based access control policies. Based on predefined security policies, access is granted only to the applications required for that role. This ensures that employees cannot access sensitive data or systems that are not related to their job responsibilities. By implementing role-based access control, organizations can improve security while maintaining efficient workflow.

Output:

- The user's identity and role are verified.
- Access policies determine the allowed applications.
- Users receive access only to authorized resources.
- Sensitive applications remain restricted to authorized roles.

Scenario 5: Secure Access from Public Network.

Employees often access company applications while traveling or working from public locations such as cafes, airports, or hotels. Public Wi-Fi networks are not always secure and may expose users to cyber threats. In this scenario, a user attempts to access a company application through a public network. This ensures that sensitive company data is protected even when accessed from untrusted networks. The user experiences secure and seamless access without exposing the internal network infrastructure.

Output:

- The connection is routed through the secure ZTNA cloud gateway.
- Data traffic is encrypted and monitored for threats.
- The user securely connects to the required application.
- Risks from public networks are minimized through security policies.

STAGE – 1

Title of the project:

Implement and manage Zero Trust Network Access (ZTNA) using Zscaler.

Overview:

Zero Trust Network Access focuses on providing **secure user-to-application connectivity** rather than traditional network-level access. Instead of allowing users to connect to the entire network, ZTNA grants access only to specific applications based on predefined security policies. These policies consider multiple factors such as user identity, device security posture, location, time of access, and compliance with organizational security standards. This ensures that only authorized users with trusted devices can access critical applications, while unauthorized users are blocked automatically.

In this project, ZTNA is implemented using **Zscaler**, a leading cloud-based cybersecurity platform that delivers secure access to applications and services without exposing internal networks to the internet. Zscaler acts as a secure cloud gateway that connects users directly to applications through an encrypted and monitored connection. When a user attempts to access an application, the system verifies their identity through authentication mechanisms and evaluates the security posture of the device being used. Only after successful verification does the system allow access to the requested application.

One of the key advantages of using Zscaler for Zero Trust Network Access is that it eliminates the need for traditional VPN infrastructure. VPNs often create security risks because they provide users with full network access after authentication. In contrast, ZTNA limits access strictly to authorized applications, preventing attackers from moving laterally within the network even if a device becomes compromised. Additionally, applications remain hidden from the public internet, reducing the risk of direct attacks or unauthorized discovery.

Another important feature of ZTNA with Zscaler is continuous monitoring and traffic inspection. All user connections and data traffic are analyzed in real time to detect potential threats, malware, or suspicious activities. Security policies are dynamically enforced to ensure that only safe and compliant connections are allowed. This proactive approach helps organizations identify and prevent security incidents before they cause significant damage.

The system also improves user experience by enabling seamless and secure access to applications from any location. Employees working from home, traveling, or using public networks can safely connect to enterprise applications without compromising security. By verifying both the user and the device, the system ensures that access remains secure regardless of where the user is located.

Furthermore, the Zero Trust approach supports modern cloud-based environments where applications may be hosted in data centers, private clouds, or public cloud platforms. Zscaler integrates with these environments to provide a unified security framework that protects applications across multiple infrastructures. This makes it easier for organizations to manage security policies, monitor user activity, and maintain compliance with security standards.

Overall, the implementation of **Zero Trust Network Access with Zscaler** provides a strong and scalable security solution for modern enterprises. It reduces the risk of cyberattacks, protects sensitive data, and ensures secure access to applications without exposing the internal network. By adopting this model, organizations can enhance their cybersecurity posture while supporting flexible work environments and digital transformation. This project demonstrates how ZTNA technology can be effectively used to secure user-to-application connectivity, improve access control, and strengthen the overall security architecture of an organization.

List of Vulnerability Table:-

S.no	Category Name	Vulnerability Name	CWE/CVE - No
1	Broken Access Control	Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')	CWE-22
2	Security Misconfiguration	J2EE Misconfiguration: Data Transmission Without Encryption	CWE-5
3	Software Supply Chain Failures	Unimplemented or Unsupported Feature in UI	CWE-447
4	Cryptographic Failures	Weak Encoding For Password	CWE-261
5	Injection	Improper Input Validation	CWE-20
6	Insecure Design	External control of file name or path	CWE-73

7	Authentication Failures	Improper Authentication	CWE-287
8	Software or Data integrity Failures	Untrusted Search Path	CWE-426
9	Security Logging and Alerting Failures	Insufficient Logging	CWE-778
10	Mishandling of Exceptional Conditions	Unchecked Return Value	CWE-252

REPORTS

1)Vulnerability Name: Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')

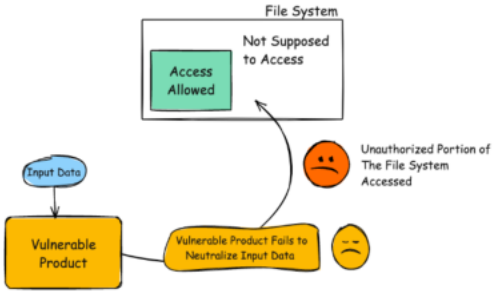
CWE/CVE: CWE-22

OWASP/SANS Category: A01:2025 Broken Access Control

Description: Path Traversal is a vulnerability that occurs when an application does not properly validate file path inputs from users. Attackers can manipulate directory paths (e.g.,.. /) to access files and directories outside the intended restricted folder.

Business Impact: Attackers may gain unauthorized access to sensitive files such as configuration files, passwords, or system data. This can lead to data breaches, exposure of confidential information, and potential system compromise. Such incidents may result in financial losses, reputational damage, and legal or regulatory consequences for the organization.

The product uses external input to construct a pathname that is intended to identify a file or directory that is located underneath a restricted parent directory, but the product does not properly neutralize special elements within the pathname that can cause the pathname to resolve to a location that is outside of the restricted directory.



Recommendations: -

1. **Input Validation and Sanitization:**
   Validate and sanitize all user inputs that are used to access files to ensure that they do not contain directory traversal characters like ../.
2. **Use Secure File Access Methods:**
   Restrict file access to predefined directories and avoid using direct user input to construct file paths.
3. **Implement Access Controls:**
   Ensure proper authentication and authorization mechanisms are in place to prevent unauthorized users from accessing sensitive resources.
4. **Use Security Libraries and Frameworks:**
   Utilize secure coding practices and built-in security features provided by programming frameworks to handle file operations safely.
5. **Regular Security Testing:**
   Conduct vulnerability scanning, penetration testing, and code reviews to detect and fix path traversal vulnerabilities early.

2)Vulnerability Name: J2EE Misconfiguration: Data Transmission Without Encryption.

CWE/CVE : CWE-5

OWASP/SANS Category: A02:2025 Security Misconfiguration

Description: Security Misconfiguration occurs when security settings in applications, servers, or databases are not properly configured or are left with default settings. This can expose systems to attackers who exploit these weaknesses to gain unauthorized access.

Business Impact: Attackers may exploit misconfigured systems to access sensitive data or system resources. It can lead to data breaches, service disruption, or unauthorized system control. This may cause financial loss, reputational damage, and potential legal consequences for the organization.

Recommendations: -

1. **Remove Default Configurations:**
   Change default usernames, passwords, and unnecessary settings to secure configurations.
2. **Regular Security Updates:**
   Keep servers, applications, and software updated with the latest security patches.
3. **Disable Unnecessary Services:**
   Turn off unused features, services, and ports to reduce the attack surface.
4. **Implement Proper Access Control:**
   Ensure only authorized users have access to sensitive system components.
5. **Perform Regular Security Audits:**
   Conduct vulnerability scans and configuration reviews to identify and fix misconfigurations.

3)Vulnerability Name: Unimplemented or Unsupported Feature in UI

CWE/CVE: CWE-447

OWASP/SANS Category: A03:2025 Software Supply Chain Failures

Description: This vulnerability occurs when a user interface includes features or options that are not fully implemented or supported by the system. Attackers may exploit these unfinished or inactive components to bypass controls or trigger unexpected system behavior.

Business Impact: Unimplemented features may expose hidden system functions or sensitive information. Attackers could exploit these weaknesses to bypass security controls or cause system errors. This can lead to service disruption, security risks, and reduced user trust in the application.

Recommendations: -

1. **Remove Incomplete Features:**
   All unfinished or unsupported features should be removed from the user interface until they are fully developed and tested.
2. **Disable Unused UI Components:**
   Buttons, links, or menu options that are not functional should be disabled to prevent users or attackers from interacting with them.
3. **Implement Proper Error Handling:**
   The system should display generic error messages and avoid revealing internal system information or code details.
4. **Conduct Regular Security Testing:**
   Perform regular vulnerability scans, penetration testing, and code reviews to identify hidden or unsupported features.
5. **Follow Secure Development Practices:**
   Developers should follow secure coding standards and thoroughly test new features before deploying them to production.

4)Vulnerability Name: Weak Encoding For Password

CWE/CVE: CWE-261

OWASP/SANS Category: A04:2025 Cryptographic Failures

Description: Weak encoding for passwords occurs when passwords are stored using insecure or easily reversible encoding methods instead of strong hashing algorithms. This makes it easier for attackers to decode or retrieve the original passwords if the database is compromised.

Business Impact: Attackers may be able to decode stored passwords and gain unauthorized access to user accounts. Compromised accounts can lead to data breaches, identity theft, and misuse of sensitive information. This can damage the organization's reputation and lead to financial or legal consequences.

Vulnerability Mapping Notes	
Usage	**ALLOWED** *(this CWE ID may be used to map to real-world vulnerabilities)*
Reason	Acceptable-Use
Rationale	This CWE entry is at the Base level of abstraction, which is a preferred level of abstraction for mapping to the root causes of vulnerabilities.
Comments	Carefully read both the name and description to ensure that this mapping is an appropriate fit. Do not try to 'force' a mapping to a lower-level Base/Variant simply to comply with this preferred level of abstraction.

Example 1

The following code reads a password from a properties file and uses the password to connect to a database.

Example Language: **Java** *(bad code)*

```
...
Properties prop = new Properties();
prop.load(new FileInputStream("config.properties"));
String password = Base64.decode(prop.getProperty("password"));
DriverManager.getConnection(url, usr, password);
...
```

This code will run successfully, but anyone with access to config.properties can read the value of password and easily determine that the value has been base 64 encoded. If a devious employee has access to this information, they can use it to break into the system.

Recommendations: -

1. **Use Strong Hashing Algorithms:**
   Passwords should be stored using strong hashing algorithms such as **bcrypt, Argon2, or PBKDF2** instead of simple encoding.
2. **Implement Password Salting:**
   Add a unique salt value to each password before hashing to protect against rainbow Table attacks.

3. **Enforce Strong Password Policies:**
   Require users to create complex passwords with a mix of letters, numbers, and special Characters.
4. **Protect the Authentication System:**
   Use secure authentication mechanisms and restrict access to password storage Databases.
5. **Perform Regular Security Audits:**
   Regularly review password storage mechanisms and perform vulnerability assessments to detect weak encoding methods.

5)Vulnerability Name: Improper Input Validation.

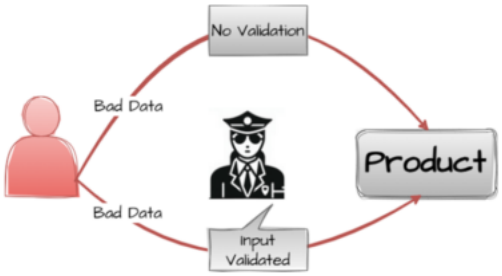
CWE/CVE: CWE-20

OWASP/SANS Category: A05:2025 Injection

Description: Injection vulnerabilities occur when untrusted user input is sent to an interpreter such as a database or command shell without proper validation. Attackers can insert malicious code (e.g., SQL, OS commands) to manipulate the system or access unauthorized data.

Business Impact: Attackers may gain unauthorized access to sensitive data stored in the database. It can lead to data modification, deletion, or complete compromise of the application. This may cause financial loss, reputational damage, and legal or regulatory issues.

The product receives input or data, but it does not validate or incorrectly validates that the input has the properties that are required to process the data safely and correctly.



Vulnerability Mapping Notes	
Usage	**DISCOURAGED** *(this CWE ID should not be used to map to real-world vulnerabilities)*
Reasons	Frequent Misuse, Frequent Misinterpretation, Abstraction
Rationale	CWE-20 is commonly misused in low-information vulnerability reports when lower-level CWEs could be used instead, or when more details about the vulnerability are available [REF-1287]. It is not useful for trend analysis. It is also a level-1 Class (i.e., a child of a Pillar). Finally, it is often used when the root cause issue is related to how input is incorrectly transformed, instead of "validated" to be correct as-is.
Comments	Within CWE, the "input validation" term focuses on the act of checking whether an input is already safe, which is different from other techniques that ensure safe processing of input. Carefully perform root-cause analysis to be sure that the issue is not due to techniques that attempt to transform potentially-dangerous input into something safe, such as filtering (CWE-790) - which attempts to remove dangerous inputs - or encoding/escaping (CWE-116), which attempts to ensure that the input is not misinterpreted when it is included in output to another component. If the issue is truly due to imroper input validation, consider using lower-level children such as Improper Use of Validation Framework (CWE-1173) or improper validation involving specific types or properties of input such as Specified Quantity (CWE-1284); Specified Index, Position, or Offset (CWE-1285); Syntactic Correctness (CWE-1286); Specified Type (CWE-1287); Consistency within Input (CWE-1288); or Unsafe Equivalence (CWE-1289).
Suggestions	

CWE-ID	Comment
CWE-1284	Specified Quantity
CWE-1285	Specified Index, Position, or Offset
CWE-1286	Syntactic Correctness
CWE-1287	Specified Type
CWE-1288	Consistency within Input
CWE-1289	Unsafe Equivalence
CWE-116	Improper Encoding or Escaping of Output
CWE-790	Improper Filtering of Special Elements

Recommendations:

1. **Input Validation:**
   Validate and sanitize all user inputs to ensure they do not contain malicious code or Commands.
2. **Use Parameterized Queries:**
   Use prepared statements or parameterized queries to prevent attackers from injecting SQL commands.
3. **Implement Proper Access Controls:**
   Restrict database permissions so that users and applications can only access necessary Data.
4. **Use Security Frameworks:**
   Use secure development frameworks and libraries that automatically protect against injection attacks.
5. **Perform Regular Security Testing:**
   Conduct regular vulnerability scans, penetration testing, and code reviews to detect and fix injection vulnerabilities.

6)Vulnerability Name: External control of file name or path.

CWE/CVE: CWE-73

OWASP/SANS Category: A06:2025 Insecure Design

Description: This vulnerability occurs when an application allows users to control or modify the file name or file path used by the system without proper validation. Attackers can manipulate the file path to access, modify, or overwrite sensitive files on the server.

Business Impact: Attackers may gain unauthorized access to sensitive files stored on the system.It can lead to data leakage, file modification, or system compromise. This may result in security breaches, financial losses, and damage to the organization's reputation.

Extended Description

This could allow an attacker to access or modify system files or other files that are critical to the application.

Path manipulation errors occur when the following two conditions are met:

1. An attacker can specify a path used in an operation on the filesystem.
2. By specifying the resource, the attacker gains a capability that would not otherwise be permitted.

For example, the program may give the attacker the ability to overwrite the specified file or run with a configuration controlled by the attacker.

Common Consequences

Impact	Details
Read Files or Directories; Modify Files or Directories	**Scope: Integrity, Confidentiality** The application can operate on unexpected files. Confidentiality is violated when the targeted filename is not directly readable by the attacker.
Modify Files or Directories; Execute Unauthorized Code or Commands	**Scope: Integrity, Confidentiality, Availability** The application can operate on unexpected files. This may violate integrity if the filename is written to, or if the filename is for a program or other form of executable code.
DoS: Crash, Exit, or Restart; DoS: Resource Consumption (Other)	**Scope: Availability** The application can operate on unexpected files. Availability can be violated if the attacker specifies an unexpected file that the application modifies. Availability can also be affected if the attacker specifies a filename for a large file, or points to a special device or a file that does not have the format that the application expects.

Recommendations: -

1. **Validate User Input:**
   Validate and sanitize all user inputs that are used to create or access file names and Paths.
2. **Restrict File Access:**
   Allow file operations only within specific authorized directories to prevent unauthorized access.
3. **Use Secure File Handling:**
   Avoid directly using user input in file system commands and use secure APIs for file operations.
4. **Implement Access Control:**
   Ensure that only authorized users have permission to access or modify important file
5. **Perform Security Testing:**
   Regularly conduct vulnerability scanning and code reviews to detect file path manipulation issues.

7)Vulnerability Name: Improper Authentication.

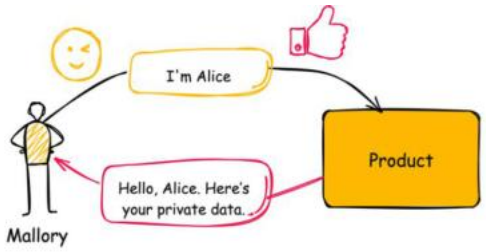
CWE/CVE CWE-287

OWASP/SANS Category: A07:2025 Authentication Failure

Description: Improper Authentication occurs when an application fails to correctly verify the identity of users before granting access to resources. Attackers can exploit weak authentication mechanisms to bypass login controls and gain unauthorized access.

Business Impact: Unauthorized users may gain access to sensitive systems or user accounts. This can lead to data theft, account takeover, or misuse of confidential information. Such incidents may cause financial loss, reputational damage, and legal consequences for the organization.

When an actor claims to have a given identity, the product does not prove or insufficiently proves that the claim is correct.



Alternate Terms	
authentification	An alternate term is "authentification", which appears to be most commonly used by people from non-English-speaking countries.
AuthN	"AuthN" is typically used as an abbreviation of "authentication" within the web application security community. It is also distinct from "AuthZ," which is an abbreviation of "authorization." The use of "Auth" as an abbreviation is discouraged, since it could be used for either authentication or authorization.
AuthC	"AuthC" is used as an abbreviation of "authentication," but it appears to used less frequently than "AuthN."

Recommendations: -

1. **Implement Strong Authentication:**
   Use secure authentication methods such as multi-factor authentication (MFA) to verify user identity.
2. **Enforce Strong Password Policies:**
   Require complex passwords and regular password updates to reduce the risk of unauthorized access.
3. **Secure Session Management:**
   Use secure session tokens and ensure sessions expire after a certain period of Inactivity.

4. **Limit Login Attempts:**
   Implement account lockout mechanisms after multiple failed login attempts to prevent brute-force attacks.

5. **Regular Security Monitoring:**
   Monitor authentication activities and perform regular security testing to detect and prevent authentication vulnerabilities.

8)Vulnerability Name: Untrusted Search Path

CWE/CVE: CWE-426

OWASP/SANS Category: A08:2025 Software or Data Integrity Failures

Description: Untrusted Search Path vulnerability occurs when an application searches for executable files or libraries in directories that may be controlled by attackers. This allows attackers to place malicious files in those locations so the system executes them instead of the legitimate ones.

Business Impact: Attackers may execute malicious programs with the same privileges as the application. This can lead to system compromise, unauthorized access, or malware installation. It may result in data loss, operational disruption, and damage to the organization's reputation.

Extended Description

This might allow attackers to execute their own programs, access unauthorized data files, or modify configuration in unexpected ways. If the product uses a search path to locate critical resources such as programs, then an attacker could modify that search path to point to a malicious program, which the targeted product would then execute. The problem extends to any type of critical resource that the product trusts.

Some of the most common variants of untrusted search path are:

- In various UNIX and Linux-based systems, the PATH environment variable may be consulted to locate executable programs, and LD_PRELOAD may be used to locate a separate library.
- In various Microsoft-based systems, the PATH environment variable is consulted to locate a DLL, if the DLL is not found in other paths that appear earlier in the search order.

Recommendations: -

1. **Use Absolute File Paths:**
   Always specify full and trusted paths for executables and system files instead of relying on search paths.
2. **Restrict Directory Permissions:**
   Limit write permissions to system directories to prevent attackers from placing malicious files.
3. **Validate Executable Sources:**
   Ensure that applications only load executables or libraries from trusted and verified locations.
4. **Implement Secure Configuration:**
   Configure the system environment variables and search paths securely to avoid untrusted directories.
5. **Perform Security Audits:**
   Regularly review application configurations and conduct vulnerability scans to detect untrusted search path issues.

9)Vulnerability Name: Insufficient Logging

CWE/CVE: CWE-778

OWASP/SANS Category: A09:2025 Security logging And Alerting Failures.

Description: Insufficient Logging occurs when an application or system does not properly record security-related events or user activities. Without proper logs and monitoring, suspicious or malicious activities may go undetected.

Business Impact: Security incidents may not be detected quickly, allowing attackers to continue their activities unnoticed. It becomes difficult to investigate attacks or identify the root cause of security breaches. This can lead to data loss, financial damage, and serious harm to the organization's reputation.

Extended Description

When security-critical events are not logged properly, such as a failed login attempt, this can make malicious behavior more difficult to detect and may hinder forensic analysis after an attack succeeds.

As organizations adopt cloud storage resources, these technologies often require configuration changes to enable detailed logging information, since detailed logging can incur additional costs. This could lead to telemetry gaps in critical audit logs. For example, in Azure, the default value for logging is disabled.

Vulnerability Mapping Notes	
Usage	ALLOWED *(this CWE ID may be used to map to real-world vulnerabilities)*
Reason	Acceptable-Use
Rationale	This CWE entry is at the Base level of abstraction, which is a preferred level of abstraction for mapping to the root causes of vulnerabilities.
Comments	Carefully read both the name and description to ensure that this mapping is an appropriate fit. Do not try to 'force' a mapping to a lower-level Base/Variant simply to comply with this preferred level of abstraction.

Recommendations: -

1. **Implement Comprehensive Logging:**
   Record important events such as login attempts, access to sensitive data, and system changes.
2. **Enable Real-Time Monitoring:**
   Use monitoring tools to detect unusual activities and potential security threats in real time.
3. **Protect Log Integrity**:
   Store logs securely and prevent unauthorized modification or deletion.
4. **Regular Log Review:**
   Periodically review and analyze logs to identify suspicious behavior.
5. **Use Security Information and Event Management (SIEM):**
   Implement SIEM tools to collect, analyze, and respond to security events efficiently.

10)Vulnerability Name: Unchecked Return Value

CWE/CVE: CWE-252

OWASP/SANS Category: A09:2025 Security logging And Alerting Failures.

Description: Unchecked Return Value occurs when a program fails to verify the return value of a function or system call. This may cause the application to continue execution even when an error or failure has occurred.

Business Impact: Ignoring return values can lead to unexpected system behavior or application crashes. Attackers may exploit these weaknesses to bypass security checks or trigger system failures. This can result in service disruption, data corruption, or reduced reliability of the application.

Description

The product does not check the return value from a method or function, which can prevent it from detecting unexpected states and conditions.

Extended Description

Two common programmer assumptions are "this function call can never fail" and "it doesn't matter if this function call fails". If an attacker can force the function to fail or otherwise return a value that is not expected, then the subsequent program logic could lead to a vulnerability, because the product is not in a state that the programmer assumes. For example, if the program calls a function to drop privileges but does not check the return code to ensure that privileges were successfully dropped, then the program will continue to operate with the higher privileges.

In the following example, it is possible to request that memcpy move a much larger segment of memory than assumed:

Example Language: **C** (bad code)

```
int returnChunkSize(void *) {

  /* if chunk info is valid, return the size of usable memory,

  * else, return -1 to indicate an error

  */
  ...
}
int main() {
  ...
  memcpy(destBuf, srcBuf, (returnChunkSize(destBuf)-1));
  ...
}
```

If returnChunkSize() happens to encounter an error it will return -1. Notice that the return value is not checked before the memcpy operation (CWE-252), so -1 can be passed as the size argument to memcpy() (CWE-805). Because memcpy() assumes that the value is unsigned, it will be interpreted as MAXINT-1 (CWE-195), and therefore will copy far more memory than is likely available to the destination buffer (CWE-787, CWE-788).

Recommendations:-

1. **Validate Return Values:**
   Always check the return value of functions and system calls to ensure operations are completed successfully.
2. **Implement Proper Error Handling:**
   Handle errors appropriately by logging them and taking corrective actions when failures Occurs.
3. **Use Secure Coding Practices:**
   Follow secure coding standards that require validation of function outputs.
4. **Conduct Code Reviews:**
   Perform regular code reviews to ensure developers are properly checking return values.
5. **Perform Testing and Debugging:**
   Use static analysis tools and thorough testing to detect unchecked return value issues Early.

STAGE – 2

Overview :-

Nessus is a vulnerability scanner developed by Tenable, Inc. It is a remote scanner, meaning that it does not need to be installed on the target host to scan it. Nessus works by sending a variety of probes to the target host in order to identify vulnerabilities. These probes can include network traffic, operating system commands, and application requests. Nessus uses a plugin-based architecture. Plugins are small pieces of code that are designed to identify specific vulnerabilities. There are over 1200 plugins available for Nessus, covering a wide range of vulnerabilities in operating systems, applications, and network devices. When Nessus scans a host, it first uses a discovery plugin to identify the operating system and services running on the host. Once the host has been discovered, Nessus runs a series of plugins to test for vulnerabilities. For each vulnerability that Nessus finds, it provides a detailed report that includes the severity of the vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications. It can also be used to scan specific ports and services. Nessus can be configured to run scans on a schedule or manually.

Here is a step-by-step explanation of how Nessus works:

1. Nessus connects to the target host using a variety of protocols, including TCP, UDP, and ICMP.
2. Nessus sends a series of probes to the target host in order to identify its operating system and services.
3. Nessus runs a series of plugins to test for vulnerabilities.
4. Nessus generates a report that includes the severity of each vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

Nessus is a valuable tool for security professionals who need to identify and remediate vulnerabilities in their networks. It is easy to use and provides comprehensive reports that can be used to priorities remediation efforts.

Here are some of the benefits of using Nessus:

- **Comprehensive vulnerability coverage:**
  Nessus has over 1200 plugins available, covering a wide range of vulnerabilities in operating systems, applications, and network devices.
- **Easy to use:**
  Nessus has a user-friendly interface that makes it easy to configure and run scans

- **Comprehensive reporting:**
  Nessus provides detailed reports that include the severity of each vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.
- **Scalability:**
  Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications.
- **Flexibility:**
  Nessus can be configured to run scans on a schedule or manually.

Nessus is a powerful tool that can be used to improve the security of any network. It is a valuable asset for any security professional.

- **Target website:** https://ginandjuice.shop/
- **Target ip address:** 34.249.203.140

List of Vulnerabilities: -

S.no	Vulnerability Name	Severity	Plugins
1	HSTS Missing From HTTPS Server (RFC 6797)	MEDUIM	142960
2	SSL Certificate Information	INFO	10863
3	SSL / TLS Versions Supported	INFO	56984
4	TLS ALPN Supported Protocol Enumeration	INFO	84821
5	Web Server Crafted Request Vendor/Version Information Disclosure	INFO	11239
6	Service Detection	INFO	22964

7	Nessus SYN scanner	INFO	11219
8	Additional DNS Hostnames	INFO	46180

REPORTS

1) Vulnerability Name: HSTS Missing From HTTPS Server (RFC 6797)

Severity: MEDIUM

Plugin: 142960

Port: 443

Description: The remote web server is not enforcing HSTS, as defined by RFC 6797. HSTS is an optional response header that can be configured on the server to instruct the browser to only communicate via HTTPS. The lack of HSTS allows downgrade attacks, SSL-stripping man-in-the-middle attacks, and weakens cookie-hijacking protections.

Solution: Configure the remote web server to use HSTS.

Business Impact: When **HTTP Strict Transport Security (HSTS)** is not enabled on the HTTPS server, users may still access the website using an unsecured **HTTP connection** before being redirected to HTTPS. This creates an opportunity for attackers to perform **man-in-the-middle (MITM) attacks**, where they can intercept, modify, or steal sensitive data transmitted between the user and the server.As a result, confidential information such as **login credentials, personal data, or session cookies** may be exposed. Attackers could exploit this vulnerability to hijack user sessions, gain unauthorized access to accounts, or manipulate communication between users and the application.

2)Vulnerability Name: SSL Certificate Information

Severity: INFO

Plugin: 10863

Port: 443

Description: This plugin connects to every SSL-related port and attempts to extract and dump the X.509 certificate.

Solution:
Ensure the SSL/TLS certificate is properly configured, valid, and does not expose unnecessary organizational or internal information in the X.509 certificate fields.

Business Impact: This vulnerability indicates that the server's **SSL/TLS certificate information is publicly accessible** when a connection is made to the HTTPS service. Attackers or security scanners can retrieve details from the **X.509 certificate**, such as the certificate issuer, validity period, domain name, and encryption details.Although this is an **informational finding and not a direct vulnerability**, the exposed certificate information can still provide useful data to attackers during the **reconnaissance phase** of an attack. By analyzing the certificate details, attackers may gain insights about the organization's infrastructure, domain structure, or certificate authority, which could help them plan **targeted attacks, phishing campaigns, or domain spoofing attempts**.

3)Vulnerability Name: SSL / TLS Versions Supported

Severity: INFO

Plugin: 56984

Port: 443

Description: This plugin detects which SSL and TLS versions are supported by the remote service for encrypting communications.

Solution: Disable outdated SSL/TLS versions and configure the server to support only secure protocols such as **TLS 1.2 and TLS 1.3**.

Business Impact: If older or insecure SSL/TLS versions are supported, attackers may exploit known protocol weaknesses to intercept encrypted communications, potentially leading to **data exposure, security breaches, and loss of customer trust**.

4)Vulnerability Name: TLS ALPN Supported Protocol Enumeration

Severity: INFO

Plugin: 84821

Port: 443

Description: The remote host supports the TLS ALPN extension. This plugin enumerates the protocols the extension supports.

Solution: Configure the server to allow only **necessary and secure ALPN protocols** (such as HTTP/2 or HTTP/1.1) and disable any unnecessary or insecure protocol support.

Business Impact: Although this is an informational finding, attackers can use the exposed **ALPN protocol information during reconnaissance** to understand the server configuration and supported protocols, which may help them plan targeted attacks if other vulnerabilities exist.

5)Vulnerability Name: Web Server Crafted Request Vendor/Version Information Disclosure

Severity: INFO

Plugin: 11239

Port: 0

Description: The web server running on the remote host appears to be hiding its version or name, which is a good thing. However, using a specially crafted request, Nessus was able to discover the information.

Solution: Configure the web server to disable detailed **server banner and version disclosure** and apply proper security headers to prevent information leakage.

Business Impact: If the web server vendor or version information is disclosed, attackers can identify the exact server software and target **known vulnerabilities specific to that version**, increasing the risk of targeted attacks and potential system compromise.

6)Vulnerability Name: Service Detection

Severity: INFO

Plugin: 22964

Port: 80

Description: Nessus was able to identify the remote service by its banner or by looking at the error message it sends when it receives an HTTP request.

Solution: Disable or modify **service banners and detailed error messages** in the web server configuration to prevent service information disclosure.

Business Impact: If service details are exposed, attackers can identify the **type and version of services running on the server**, which may help them target known vulnerabilities and increase the risk of potential attacks.

7)Vulnerability Name: Nessus SYN scanner

Severity: INFO

Plugin: 11219

Port: 80

Description: This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target.

Solution: Protect your target with an IP filter.

Business Impact: This is an informational finding indicating that the port is reachable and responds to SYN scan requests. If attackers can identify open ports through such scans, they may use this information to discover running services and attempt **further reconnaissance or targeted attacks** against exposed services on the system.

8)Vulnerability Name: Additional DNS Hostnames

Severity: INFO

Plugin: 46180

Port: N/A

Description: Hostnames different from the current hostname have been collected by miscellaneous plugins. Nessus has generated a list of hostnames that point to the remote host. Note that these are only the alternate hostnames for hosts discovered on a web server. **Solution:** If you want to test them, re-scan using the special vhost syntax, such as : www.example.com[192.0.32.10]

Business Impact: The presence of additional DNS hostnames may expose **extra domains or subdomains associated with the server**, which attackers can use for reconnaissance to discover hidden services, misconfigured systems, or potential entry points for further attacks.

STAGE – 3

REPORTS:

Title: Implement and manage Zero Trust Network Access (ZTNA) using Zscaler.

• Zero Trust Network Access (ZTNA)

Zero Trust Network Access (ZTNA) is an IT security framework that provide secure remote access to an organization's internal applications and data based on clearly defined access control policies. Unlike traditional Virtual Private Networks (VPNs), which grant users broad access to the entire network, ZTNA operates on a "never trust, always verify" principle. It grants users access only to the specific applications they need, and only after their identity and device have been verified. ZTNA is a critical component of modern security architecture. It helps organizations move away from the concept of a trusted internal network and an untrusted external network (the "castle- and-moat" model). By hiding the internal network from the internet and establishing one-to-one, encrypted connections between users and applications, ZTNA drastically reduces the attack surface and stops common threats like lateral movement by attackers.

• The ZTNA Access Cycle

The ZTNA cycle is a continuous process of verifying identity, establishing secure connections, and enforcing policy for every access request. It typically consists of the following steps:

1. User Request: A user, from any location (office, home, coffee shop), requests access to a specific internal application (e.g., an HR portal, a finance server, or an internal code repository).

2. Identity and Device Verification: Before any connection is established, the ZTNA solution verifies who the user is (via multi-factor authentication, or MFA) and checks the security posture of their device. This includes ensuring the device has up-to-date antivirus, a healthy firewall, and is not compromised.

3. Policy Enforcement: The ZTNA solution checks the access policy. Does this specific user, with this specific device, have permission to access the requested application at this specific time?

4. Establish Secure Connection: If the policy allows access, the ZTNA solution creates a highly secure, encrypted micro-tunnel between the user's device and the target application. Crucially, the user never gains access to the underlying network, only to the application itself.

5. Continuous Monitoring: The ZTNA solution continues to monitor the connection for anomalies. If the user's behavior becomes suspicious or their device posture changes, the connection can be terminated in real-time.

6. Logging and Analytics: All access attempts, successful and failed, are logged and analyzed. This data is used for auditing, threat hunting, and refining access policies.

• Zscaler (Zscaler Internet Access / Zscaler Private Access)

Zscaler is a cloud-native security platform that delivers its services entirely from the cloud, eliminating the need for on-premises hardware like VPN concentrators. For ZTNA, Zscaler offers Zscaler Private Access (ZPA) . ZPA is a service that provides seamless, identity-based access to private applications without ever placing users on the network. Zscaler ZPA operates on a simple principle: the application is "inside" the Zscaler cloud, and the user connects to it there. It collects data from a variety of sources, including:

1. Identity Providers (IDP): Such as Azure AD, Okra, or Ping Identity, to verify user identities.

2. Device Posture Partners: Such as CrowdStrike, Tanium, or Microsoft Defender for Endpoint, to check the health of the endpoint.

3. Business Applications: The internal web apps, file servers, and legacy applications hosted in data centers or public clouds (e.g., AWS, Azure).

4. Zscaler App Connectors: Lightweight software components deployed in the data center or cloud that initiate outbound connections to the Zscaler cloud, making internal servers invisible to the internet.

Zscaler then enforces policies based on this data, including:

1. Identity-Based Access: Policies are built around user and group identities, not IP addresses.

2. Application Segmentation: Users are granted access to specific applications, not entire subnets.

3. Least Privilege Access: Ensures users have the minimum level of access required to perform their jobs.

• The Zscaler ZTNA Cycle

The Zscaler ZTNA cycle is the practical application of the ZTNA principles using the Zscaler cloud. The cycle typically consists of the following steps:

1. User Login and Authentication: A user attempts to access an internal application. They are redirected to their organization's Identity Provider (IDP) for authentication and MFA.

2. Device Posture Check (Integration): Zscaler checks with integrated endpoint protection tools to ensure the device is compliant with security policies.

3. Policy Lookup and Decision: The Zscaler cloud evaluates the request against the defined access policies. It verifies that the user, device, and context (time, location) are authorized for that specific application.

4. Establishing the Micro-tunnel: Once authorized, the Zscaler cloud instructs the user's Zscaler Client Connector and the appropriate Zscaler App Connector in the data center to establish an encrypted connection. The user is now connected to the application.

5. Traffic Inspection (Optional): For sanctioned applications, Zscaler can optionally inspect the traffic for data loss prevention (DLP) or to detect malware.

6. Logging and Analytics: All activity is logged in the Zscaler cloud portal for reporting, threat hunting, and compliance.

• MISP (Malware Information Sharing Platform) Integration

While Zscaler is a primary access control tool, it can be enhanced by integrating with threat intelligence platforms like MISP.

1. Threat Intelligence Feed: MISP can aggregate and share threat intelligence about malicious domains, IPs, and URLs. This list of indicators of compromise (IOCs) can be fed into Zscaler's cloud.

2. Proactive Blocking: If a user, even one authorized by ZPA, attempts to access a known malicious site that has been flagged by the MISP feed, Zscaler Internet Access (ZIA) can block the request, preventing a potential infection.

3. Enhanced Visibility: Security teams can use MISP to cross-reference Zscaler logs. If a user's behavior is anomalous, the team can check MISP to see if the destination IP or domain is associated with a known threat actor or campaign.

• Your College Network Information

This infrastructure presents a large attack surface, especially with the need for remote learning and administrative access.

The network includes:

- Core routers and switches
- Distribution routers and switches
- Wireless access points
- Firewalls and Intrusion Detection Systems (IDS)
- Internal Application Servers: Hosting the student information system, library resources, research data repositories, and administrative portals.
- Legacy VPN Concentrator: Currently providing broad network-level access for faculty and staff working remotely.

The need for ZTNA arises from the limitations of the current VPN model:

- **Over-permissioned Access:** Once on the VPN, a faculty member's compromised laptop could potentially scan and attack the entire internal network (lateral movement).
- **Hidden Applications:** Some research applications need to be accessed by external collaborators without granting them full network access.
- **User Experience:** The legacy VPN can be slow and cumbersome, often requiring users to route all their internet traffic through the university.

How you think you deploy ZTNA using Zscaler in your college

To deploy Zscaler ZTNA (ZPA) in your college, you would start by identifying the specific applications that need to be secured and the user groups that need access to them. This is a shift from securing the network to securing access to applications.

The plan would need to include the following:

1. Application Discovery: Catalog all internal applications (e.g., ERP, library system, research servers, file shares) and identify which ones are currently exposed via the VPN.

2. User Segmentation: Define user groups (e.g., Students, Faculty - Research, Faculty - Admin, IT Staff, External Collaborators) and the specific applications each group needs.

3. Deploying Zscaler App Connectors: Install lightweight App Connector VMs in the university's data center. These connectors will establish outbound connections to the Zscaler cloud, making the application servers invisible to the public internet.

4. Integrating Identity Provider: Connect Zscaler to the university's existing Identity Provider (e.g., Microsoft Azure AD) to leverage current usernames, passwords, and MFA policies.

5. Configuring Access Policies: Create granular policies in the Zscaler admin portal. For example: "The 'Faculty' group can access the 'ERP Application' from any device that has antivirus enabled, after MFA."

6. Deploying Zscaler Client Connector: Students, faculty, and staff will install the Zscaler Client Connector on their laptops and mobile devices. This small client intelligently routes traffic for private applications through ZPA and public traffic through ZIA.

Threat Intelligence

In the context of Zscaler and ZTNA, threat intelligence is used to understand who is trying to access what, and from where. It helps move beyond simple identity checks to a more contextual understanding of risk.

Sources include:

1. Zscaler Cloud Logs: Internal logs provide real-time data on who is accessing which applications, from which locations, and on what devices.

2. External Threat Feeds (MISP): Information about new malware campaigns, phishing kits, or command-and-control servers being used by attackers.

3. Identity Provider Logs: Anomalies in login attempts, such as a user logging in from two geographically impossible locations in a short time, can signal a compromised account.

This intelligence is used for:

1. Adaptive Access Control: If threat intelligence suggests a user's location is high-risk, Zscaler can step-up authentication requirements or block access entirely.

2. Hunting for Compromised Accounts: Analysts can use Zscaler logs to see if a user is suddenly accessing applications they never have before, which could be a sign of credential theft.

3. Blocking Malicious Communication: Threat intelligence feeds can be used by Zscaler Internet Access (ZIA) to block outbound connections to known malicious sites, even if they originate from a user inside the university.

Incident Response (Adapted for ZTNA)

Incident response in a ZTNA model is faster and more targeted because the environment is inherently more controlled.

1. Detection: The SOC team detects an anomaly. For example, a faculty account is downloading an unusually high volume of data from a research server at 3 AM. Zscaler logs provide the exact details: the user, the device, the application, and the amount of data transferred.

2. Containment: The SOC team can instantly isolate the user. In the Zscaler portal, they can simply deactivate that user's access or block their specific device. Because there is no network- level access, this action immediately severs all connections to every application, preventing lateral movement.

3. Eradication: The compromised device is taken offline for malware scanning and cleaning by the IT helpdesk.

4. Recovery: Once the device is clean and the user's password is reset, the Zscaler policy is re-enabled, granting the user access again.

5. Post-incident review: The security team analyzes the logs to understand how the account was compromised (e.g., a phishing email) and updates Zscaler policies, perhaps by adding a block for similar malicious domains or tightening access rules for that specific research application.

Benefits of this incident response approach:

1. Near-Instant Containment: Actions take seconds in a cloud dashboard, not minutes or hours configuring firewall rules.

2. No Lateral Movement: The attacker is contained to the single compromised application, protecting the rest of the university's network.

3. Granular Forensics: Zscaler provides a detailed audit trail of every connection, making investigations faster and more accurate.

4. Compliance: This model helps demonstrate compliance with data protection regulations by proving that access to sensitive student or research data is tightly controlled and audited.

Understanding about the tool (Zscaler ZPA)

Zscaler Private Access (ZPA) is a cloud service that embodies the ZTNA principle of "connect a user to an app, not the network."

Here are the key things to understand:

1. It is "Application-Centric," Not "Network-Centric": You define policies based on applications (e.g., "SAP Server 01"), not network constructs like IP subnets. This aligns security with how businesses actually operate.

2. It Hides the Network: ZPA uses App Connectors inside your data center that only make outbound connections to the Zscaler cloud. Your internal servers never need to open inbound firewall ports, making them invisible to port scanners and attackers on the internet.

3. It uses a "Dark Cloud" Approach: To an external scanner, the organization's applications simply don't exist. They only become visible to authorized users after a multi-step verification process.

4. It Provides a Superior User Experience: Users don't have to mess with clunky VPN clients. The Zscaler Client Connector works silently in the background. For web apps, access can even be agentless, requiring only a modern browser.

5. It is Inherently Scalable: Because it's a cloud service, ZPA scales instantly to handle thousands of concurrent users, unlike a legacy VPN appliance that needs to be manually upgraded.

Conclusion:

In conclusion, exploring the realm of AI for web security using IBM QRadar has been an insightful journey through various stages.

Stage 1: understanding web application testing unveiled the critical importance of assessing vulnerabilities and ensuring the security of web-based systems. This foundational knowledge served as a cornerstone for comprehending the subsequent stages. Stage 1 illuminated the evolving landscape of web application testing. With advancements in AI, there is a promising avenue for more sophisticated testing methodologies, ensuring even higher levels of security for web applications.

Stage 2: delved into the intricacies of Nessus reports, emphasizing the significance of detailed vulnerability assessments. Analyzing these reports provided valuable insights into potential threats, enabling informed decision-making for robust security measures. Stage 2 highlighted the future trajectory of the testing process, indicating a shift towards more automation and integration

of AI-driven tools. This evolution promises quicker, more accurate vulnerability assessments, enhancing overall cybersecurity postures.

Stage 3: introduced the pivotal concept of Zero Trust Network Access (ZTNA) and its implementation using Zscaler Private Access (ZPA). It demonstrated a paradigm shift from traditional VPN-based network access to secure, identity-based user-to-application connectivity. The solution showcased the power of hiding internal applications from the internet, enforcing granular access policies, and eliminating lateral movement. This underscores the need for modern, proactive cybersecurity strategies in an era of remote work and cloud adoption. Stage 3 illuminated the future potential of Zero Trust Network Access (ZTNA) and Zscaler technologies. With AI integration and machine learning, these systems are poised to become more intelligent and adaptive, enabling real-time risk assessment based on user behavior and device posture. Enhanced automation in policy enforcement, predictive analytics for threat detection, and improved scalability are anticipated, empowering organizations to stay ahead of sophisticated cyber threats in an increasingly distributed world.

In essence, the project not only provided a deep understanding of the current state zero trust using ZSCALER but also offered a glimpse into the exciting future of cybersecurity. Embracing these advancements will be crucial for organizations aiming to fortify their digital landscapes in the face of ever-evolving cyber threats.

Future Scope:

1)Future of web application testing

The future of WAT is bright, as web applications become increasingly complex and sophisticated. Organizations are increasingly reliant on web applications to conduct business, and they need to be confident that their web applications are secure and reliable.

Here are some of the key trends that are expected to shape the future of WAT:

- **Increased focus on security:** Security is a top priority for all organizations, and WAT is essential for identifying and mitigating security vulnerabilities. In the future, we can expect to see even more emphasis on security testing, as web applications become increasingly targeted by cyberattacks.
- **Rise of artificial intelligence (AI) and machine learning (ML):** AI and ML are already being used in WAT, and their role is expected to grow in the future. AI and ML can be used to automate repetitive tasks, such as test case generation and execution. They can also be used to identify complex patterns and anomalies that may be difficult to detect with traditional testing methods.
- **Shift to cloud-based testing:** More and more organizations are moving their web applications to the cloud. This trend is driving the growth of cloud-based WAT platforms. Cloud based testing platforms offer a number of advantages, such as scalability, flexibility, and cost-effectiveness.
- **Increased focus on user experience (UX) testing:** UX testing is essential for ensuring that web applications are easy to use and meet the needs of users. In the future, we can expect to see more focus on UX testing, as organizations increasingly recognize the importance of providing a positive user experience.

2)Future scope of the testing process

The future scope of the testing process is bright, as software becomes increasingly complex and sophisticated. Organizations are increasingly reliant on software to conduct business, and they need to be confident that their software is high-quality and reliable.

Here are some of the key trends that are expected to shape the future of the testing process:

- **Increased focus on continuous testing:** Continuous testing is a methodology that involves testing software throughout the SDLC, from development to deployment. This helps to identify defects early and prevent them from causing problems later in the development process.
- **Rise of AI and ML:** AI and ML are already being used in the testing process, and their role is expected to grow in the future. AI and ML can be used to automate repetitive tasks, such as test case generation and execution. They can also be used to identify complex patterns and anomalies that may be difficult to detect with traditional testing methods.

- **Shift to cloud-based testing:** Cloud-based testing platforms offer a number of advantages, such as scalability, flexibility, and cost-effectiveness. This is driving the growth of cloud-based testing platforms.
- **Increased focus on testing automation:** Testing automation is the use of software to execute test cases without human intervention. Testing automation can help to save time and resources, and it can also help to improve the quality and efficiency of testing.

3)Future scope of SOC / SEIM:

The future scope of Zero Trust Network Access (ZTNA) and the broader Zero Trust framework is poised for significant evolution, driven by emerging technologies and changing threat landscapes:

1. AI-Driven Zero Trust (AI-ZTA): Future Zero Trust implementations will leverage advanced AI and deep learning to move beyond static policies. Systems will continuously learn user behavior, predict anomalous activities before they occur, and dynamically adjust access privileges in real-time based on contextual risk, creating a truly "adaptive" security posture.

2. Integration with Edge Computing and IoT: As organizations deploy more IoT devices and edge computing nodes, Zero Trust principles will extend to these resource-constrained environments. Expect the development of lightweight Zero Trust agents and protocols that can authenticate and secure machine-to-machine (M2M) communication at the edge, preventing large-scale botnet attacks.

3. Identity-Centric Everything: The future will see identity become the ultimate security perimeter. Zero Trust will evolve to incorporate advanced identity verification methods, including continuous behavioral biometrics (keystroke dynamics, gait analysis) and decentralized identity solutions using blockchain, ensuring that the user behind the session is verified at all times.

4. Convergence with SASE Architecture: Zero Trust will be a core component of the Secure Access Service Edge (SASE) framework. This convergence will provide organizations with a unified, cloud-delivered stack that combines ZTNA, Secure Web Gateways (SWG), Cloud Access Security Brokers (CASB), and Firewall-as-a-Service (FWaaS), simplifying management and ensuring consistent security for all users, regardless of location.

5. Zero Trust for Operational Technology (OT) and Critical Infrastructure: Sectors like energy, manufacturing, and healthcare will increasingly adopt Zero Trust to protect critical

infrastructure. Future scope includes air-gapped Zero Trust solutions and specialized protocols designed to secure legacy industrial control systems (ICS) and SCADA environments from nation-state attacks.

6. Automated Threat Hunting and Response: Future Zero Trust platforms will integrate with Security Orchestration, Automation, and Response (SOAR) tools to enable automated threat hunting. Upon detecting a compromised identity or device, the system will not just block access but automatically initiate investigation playbooks, and even roll back malicious changes.

Topics explored:

Data Collection and Aggregation, Standardization and Normalization, Enrichment and Analysis, Sharing and Distribution, Integration with Security Tools, Customization and Flexibility, Automation and Orchestration, Community Involvement, Incident Response Support, Threat Intelligence Feeds, Soc and Siem

Tools explored:

Nmap, Metasploit, Nessus, Kali Linux, OWASP ZAP, Burp Suite

THE END